UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

05 - PLAN DE RESPUESTA ANTE INCIDENTES

CNO IV Programación WAP

Maestro: Servando López Contreras

Lopez Alcocer Monica Isabel - 179827

Contenido

1. Propósito, alcance y clasificación
2. Roles y responsabilidades
3. Preparación, detección y reporte
4. Análisis y priorización
5. Contención
6. Erradicación y remediación
7. Recuperación
8. Coordinación y comunicación
9. Playbooks operativos
10. Post-incidente y mejora

1. Propósito, alcance y clasificación

> **Propósito.** Este Plan de Respuesta ante Incidentes (PRI) establece la estrategia y los procedimientos con los que **INTERAFAS** detecta, analiza, contiene, erradica y se recupera de incidentes de ciberseguridad que afecten la operación del agua, los datos de la ciudadanía o la reputación institucional, limitando su impacto y restableciendo la operación segura en el menor tiempo posible. Toma como caso de referencia el incidente simulado en el ejercicio **INTERAFAS-LAB** y, como referencia metodológica, los *Federal Government Cybersecurity Incident and Vulnerability Response Playbooks* (CISA, 2021/2024) y la guía NIST SP 800-61.

1.1 Alcance

- Aplica a **todos los activos de información y de operación (IT y OT)** de INTERAFAS: el portal y las aplicaciones web, las bases de datos y expedientes de la ciudadanía, la infraestructura de red, los sistemas de pago y los sistemas de control industrial (SCADA/PLC) del proceso de distribución de agua.
- Obliga a **todo el personal, mandos y terceros** (proveedores y soporte externo) que operen, administren o accedan a dichos activos.
- Cubre el ciclo completo de respuesta: **preparación, detección y análisis, contención, erradicación, recuperación y actividades post-incidente**, además de la coordinación transversal.
- Se articula con el **SGSI (ISO/IEC 27001)**, con el **Plan de Comunicación de Crisis** (entregable 04) y con los planes de continuidad del servicio.

1.2 Concepto de incidente

Concepto	Definición operativa
Evento de seguridad	Cualquier ocurrencia observable en un sistema o red (p. ej., un intento de acceso, una alerta del WAF). No implica, por sí mismo, un daño.
Incidente de seguridad	Evento o serie de eventos que **compromete o amenaza** la confidencialidad, integridad o disponibilidad de la información o de la operación, o que viola las políticas de seguridad.
Incidente OT	Incidente que afecta —o puede afectar— el proceso físico de distribución de agua (cambios de parámetros, pérdida de control, integridad de firmware).
Casi-incidente	Evento que pudo convertirse en incidente y fue evitado por un control; se registra para aprendizaje.

1.3 Criterios de severidad

La severidad se determina combinando tres atributos de impacto (NIST SP 800-61): **impacto funcional** (sobre la operación y el servicio de agua), **impacto a la información** (datos de la ciudadanía) y **esfuerzo de recuperación**.

Nivel	Criterio	Ejemplo en INTERAFAS	Respuesta objetivo
SEV-1 · Crítico	Pérdida de control del proceso de agua, riesgo a la seguridad física o exposición masiva de datos.	Cruce IT→OT y sobrepresión (cascada de 5 etapas, disponibilidad 4.1 %).	Activación total; CCC y Dirección; atención 24/7.
SEV-2 · Alto	Afectación parcial a datos o a servicios clave; explotación activa confirmada.	Acceso a expedientes de ciudadanos (IDOR/BOLA) o fraude en pagos.	Equipo IR completo; vocería activa.
SEV-3 · Medio	Afectación limitada y contenida, sin impacto al servicio ni a datos sensibles.	Inyección detectada y bloqueada por el WAF antes de exfiltrar.	Equipo técnico; seguimiento formal.
SEV-4 · Bajo	Evento aislado o casi-incidente; sin impacto.	Exposición de un archivo sin datos sensibles, ya retirado.	Atención en horario; registro.

1.4 Prioridad de atención

Dentro de un mismo nivel, la prioridad se afina con la matriz de atributos. En una infraestructura crítica de agua, el **impacto funcional y la seguridad física prevalecen** sobre otros factores.

Atributo	Escala	Qué pondera
Impacto funcional	Nulo · Bajo · Medio · Alto	Grado de afectación a la operación y al suministro de agua.
Impacto a la información	Nulo · Privacidad · Integridad · Propietario	Exposición o alteración de datos de la ciudadanía y de la operación.

Atributo	Escala	Qué pondera
Esfuerzo de recuperación	Normal · Reforzado · Extendido · No recuperable	Recursos y tiempo estimados para restablecer la operación segura.

1.5 Condiciones de activación

- El **SOC/CISO confirma** un incidente con impacto real o potencial sobre el servicio de agua, los datos de la ciudadanía o la reputación.
- Se detecta **explotación activa**, exfiltración de datos o una **anomalía en OT** (cambio de parámetro, firmware no autorizado, pérdida de telemetría).
- El asunto **trasciende a medios o redes** o lo reporta un tercero/autoridad.
- En **SEV-1 y SEV-2** la activación del PRI **dispara también el Plan de Comunicación de Crisis** (entregable 04) y la notificación a Dirección General.

> **Referencia metodológica.** Las fases de este plan se alinean con el *Incident Response Playbook* de CISA (Preparación; Detección y análisis; Contención, erradicación y recuperación; Actividad post-incidente; y Coordinación como eje transversal) y con el *Vulnerability Response Playbook* (identificación, evaluación, remediación y notificación), aplicados al contexto de INTERAFAS-LAB.

2. Roles y responsabilidades

La respuesta se conduce a través del **Equipo de Respuesta a Incidentes (ERI / CSIRT)**, activado por el CISO. Cada incidente tiene un **líder de incidente** único que coordina las acciones y es el punto de decisión técnico.

2.1 Equipo de respuesta y funciones

Rol	Responsabilidad en la respuesta
Líder de incidente (IC)	Coordina todo el ciclo, asigna tareas, decide contención/erradicación/recuperación, mantiene la bitácora y reporta al CISO. Es la **única autoridad** de la respuesta técnica.
CISO	Activa el plan, define severidad, autoriza acciones de alto impacto, escala a Dirección y enlaza con el Comité de Comunicación de Crisis.
Analistas SOC / respuesta	Detección, triage, análisis, forense, contención y erradicación técnica; preservan la evidencia.
Operaciones (OT)	Confirman el estado del proceso de agua, ejecutan maniobras seguras y validan la recuperación de OT; priorizan la seguridad física y la continuidad.
TI / Infraestructura	Aplican parches, aislamientos de red, restauración de sistemas y segmentación.
Dirección General	Aprueba decisiones de nivel crítico, provee recursos y asume la postura institucional.
Jurídico	Determina obligaciones de notificación (INAI), resguarda la cadena de custodia legal y acota riesgos.
Comunicación / Vocería	Gestiona los mensajes conforme al Plan de Comunicación de Crisis; no comunica por su cuenta.
Terceros (proveedores, forense, fabricante de firmware)	Apoyan bajo contrato y acuerdos de confidencialidad; se coordinan siempre a través del líder de incidente.

2.2 Matriz RACI por fase

R = Responsable · A = Aprueba · C = Consultado · I = Informado.

Fase	ERI/IC	CISO	Oper. OT	Dir. Gral.	Jurídico	Comunic.
Preparación	R	A	C	I	C	C
Detección y análisis	R	A	C	I	I	I
Contención	R	A	C	I	C	I
Erradicación / remediación	R	A	C	I	I	I
Recuperación	R	A	R	A	I	I
Coordinación / comunicación	C	R	C	A	C	R
Post-incidente y mejora	R	A	C	C	C	C

3. Preparación, detección y reporte

3.1 Preparación

La capacidad de respuesta se sostiene en controles y recursos dispuestos **antes** del incidente, en su mayoría provenientes del SGSI (ISO/IEC 27001, entregable 03):

- **Controles preventivos:** gestión de accesos y MFA, segmentación IT/OT con firewall, firma de firmware, respaldos cifrados y probados, endurecimiento y gestión de vulnerabilidades.
- **Herramientas de visibilidad:** SIEM con correlación de eventos, WAF, IDS/IPS, EDR en endpoints y servidores, y **monitoreo específico de OT** (telemetría, integridad de firmware y rangos de setpoint).
- **Recursos de respuesta:** inventario de activos actualizado, directorio de contactos y guardias 24/7, kit forense, acuerdos con proveedores y plantillas de este plan.
- **Capacitación y simulacros:** microcurso de concientización (flyer y curso OT del SGSI), ejercicios de mesa y simulacros periódicos de respuesta.

3.2 Fuentes de detección

Fuente	Qué detecta
SIEM / correlación	Patrones anómalos, accesos indebidos, exfiltración, uso de cuentas sospechosas.
WAF / IDS-IPS	Ataques web (inyección SQL, XSS almacenado), recorridos de ruta y escaneos.
EDR	Ejecución de código malicioso, persistencia y movimiento lateral.
Monitoreo OT/ICS	Cambios de parámetros fuera de rango, firmware no firmado, pérdida de telemetría o avalancha de alarmas.
Reportes de personas	Avisos del personal, de la ciudadanía o de terceros y autoridades.
Inteligencia y auditoría	Threat intel, hallazgos de pentest y del ejercicio INTERAFAS-LAB.

3.3 Recepción de alertas, registro y canales de reporte

- **Punto único de recepción:** el **SOC (24/7)** concentra todas las alertas y reportes y abre el caso.
- **Canales de reporte:** correo `seguridad@interafas.gob`, extensión **2727**, formulario interno de reporte y línea de atención a la ciudadanía.
- **Registro:** cada incidente recibe un **identificador único** en el sistema de tickets, con fecha/hora, fuente, severidad preliminar, activos afectados y responsable. Toda acción se documenta en la **bitácora del incidente**.

> **Cultura de reporte.** Reportar temprano no se penaliza: un casi-incidente reportado a tiempo es una oportunidad de mejora. La demora o el silencio —error observado en INTERAFAS-LAB— es lo que agrava la crisis.

4. Análisis y priorización

Recibida la alerta, el objetivo es **confirmar, dimensionar y priorizar** el incidente preservando la evidencia desde el primer momento.

Paso	Acción
Triage	Determinar si la alerta es un **incidente real** o un falso positivo; descartar causas benignas.
Validación	Correlacionar indicadores en SIEM, WAF, EDR y OT para confirmar el hecho y su naturaleza.
Determinación de alcance	Identificar sistemas, datos, cuentas y activos OT afectados, y la posible propagación.
Clasificación	Asignar el **tipo** (web, control de acceso, OT, fraude, etc.) y la **severidad** (SEV-1 a SEV-4).
Priorización	Aplicar la matriz de impacto funcional / información / recuperación y ordenar la atención.
Preservación de evidencia	Imágenes forenses, resguardo de logs, **hash de integridad** y **cadena de custodia** documentada antes de alterar los sistemas.
Escalamiento	Notificar al CISO y, según severidad, a Dirección, Jurídico y al Comité de Comunicación de Crisis.

> **Regla de evidencia.** Siempre que sea posible, se **preserva antes de contener**: se capturan memoria, registros y evidencia volátil para no destruir rastros necesarios para la investigación y la eventual notificación legal.

5. Contención

La contención busca **detener la propagación y el daño** sin destruir evidencia y, en OT, **sin comprometer la seguridad física ni la continuidad** del suministro.

5.1 Contención inmediata (corto plazo)

- Aislar los hosts o segmentos afectados y, ante indicios de cruce IT→OT, **cerrar el paso por el firewall** y separar la red OT.
- Deshabilitar cuentas comprometidas o creadas por el atacante y **rotar credenciales**; bloquear direcciones IP y sesiones maliciosas.
- Poner el WAF en modo bloqueo para los vectores activos (inyección, XSS) y retirar de inmediato los recursos expuestos (respaldos, `.bak`, secretos).
- Tomar **snapshots** y asegurar respaldos antes de cualquier cambio.

5.2 Contención prolongada (largo plazo)

- Mantener la operación sobre sistemas limpios y vigilados mientras se erradica la causa raíz.
- Aplicar reglas de monitoreo y parches temporales (virtual patching) hasta la corrección definitiva.
- Reforzar la segmentación y los controles de acceso en el perímetro afectado.

5.3 Criterios de decisión

La estrategia de contención se elige ponderando (NIST SP 800-61): **daño potencial y robo de recursos, necesidad de preservar evidencia, disponibilidad del servicio** (el agua es prioritario), tiempo y recursos requeridos, eficacia de la medida y duración de la solución. En OT, cualquier maniobra se coordina con Operaciones y prioriza la **seguridad de las personas**.

6. Erradicación y remediación

Contenido el incidente, se **elimina la causa raíz** y se corrigen las debilidades que lo hicieron posible, validando los controles **antes** de recuperar.

- **Eliminación de la causa:** cerrar el vector de entrada y remediar las vulnerabilidades explotadas (las observadas en INTERAFAS-LAB: control de acceso roto, inyección, exposición de información, OT/firmware).
- **Eliminación de persistencia:** eliminar cuentas creadas por el atacante, webshells, tareas programadas y accesos residuales; **rotar todas las credenciales** potencialmente comprometidas.
- **Corrección de vulnerabilidades:** autorización por objeto (contra IDOR/BOLA), consultas parametrizadas y validación/codificación de salida (contra SQLi/XSS), retiro de respaldos y secretos expuestos, **verificación de firma de firmware**, segmentación IT/OT y no confiar en cabeceras como `X-Forwarded-For` para autorizar.
- **Validación de controles:** re-prueba técnica (pentest de verificación) que confirme que cada hallazgo quedó cerrado y que no persisten indicadores de compromiso.

> **No se recupera hasta validar.** La transición a recuperación requiere la confirmación del líder de incidente de que la causa raíz fue eliminada y los controles corregidos fueron verificados.

7. Recuperación

La recuperación restablece la operación **de forma segura, gradual y verificada**, con capacidad de revertir si reaparecen indicadores.

Elemento	Procedimiento
Restauración segura	Restaurar desde **respaldos limpios y verificados** (integridad por hash); reconstruir sistemas comprometidos desde una base confiable.
Pruebas previas	Verificar funcionalidad y seguridad en un entorno controlado antes de volver a producción.
Restauración por fases	Reactivar primero los servicios IT validados y, al final y con validación específica, los sistemas **OT**.
Monitoreo reforzado	Elevar el nivel de registro y alertas durante un periodo de observación posterior al restablecimiento.
Criterios de retorno	Controles validados, sin indicadores de compromiso y **autorización del líder de incidente y de Operaciones** (y de Dirección General en SEV-1).
Mecanismos de rollback	Puntos de restauración y respaldos listos para **revertir** de inmediato si reaparece actividad maliciosa o inestabilidad del proceso.

8. Coordinación y comunicación

La coordinación es un **eje transversal** a todas las fases (CISA). La respuesta técnica y la comunicación institucional operan de forma alineada pero diferenciada: el ERI maneja el incidente; el **Comité de Comunicación de Crisis** maneja el mensaje.

8.1 Escalamiento ejecutivo

- Línea de escalamiento: **líder de incidente → CISO → Dirección General**, con umbrales por severidad.
- En **SEV-1/SEV-2** el CISO informa a Dirección General y activa el Plan de Comunicación de Crisis; cualquier integrante del ERI puede solicitar escalar.

8.2 Enlace con comunicación de crisis

El líder de incidente alimenta la **fuente única de verdad** con hechos técnicos verificados y define qué información es segura divulgar; la vocería construye y difunde los mensajes conforme al entregable 04. Así se evita exponer detalles técnicos explotables.

8.3 Coordinación externa

Actor	Motivo de la coordinación
CONAGUA / autoridad del agua	Afectación o riesgo al servicio de agua y a la infraestructura crítica.
INAI	Notificación por posible vulneración de datos personales de la ciudadanía.
Policía cibernética / CERT	Apoyo en investigación, inteligencia de amenazas y seguimiento legal.
Protección civil	Coordinación si hay riesgo a la población por el proceso físico.
Proveedor / fabricante	Proveedor comprometido (cadena de suministro) y fabricante de firmware para parches y verificación.
Forense externo	Apoyo especializado en incidentes de alta complejidad.

9. Playbooks operativos

Seis playbooks derivados de los escenarios observados en **INTERAFAS-LAB**. Cada uno define disparador, responsables, acciones de detección y análisis, contención, erradicación/remediación, recuperación, evidencia a preservar y criterio de cierre.

PB-01	**Exposición y fuga de información sensible** Escenarios OPEN-DOOR, LOOK-CLOSER, OLD-MEMORIES, TOO-MUCH-INFO, HIDDEN-HISTORY (directorios abiertos, respaldos y archivos .bak, secretos y datos expuestos).
Disparador	Alerta de acceso a rutas/archivos sensibles, hallazgo de respaldos o secretos accesibles, o reporte externo de información expuesta.
Responsables	Líder de incidente · SOC · TI/Infraestructura · Jurídico (si hay datos personales).
Detección y análisis	• Confirmar qué recursos quedaron accesibles y desde cuándo (logs de acceso). • Determinar si contienen datos personales, credenciales o información de la operación.
Contención	• Retirar de inmediato los archivos y directorios expuestos; cerrar el listado de directorios. • Invalidar y **rotar** credenciales o secretos revelados.
Erradicación / remediación	• Eliminar respaldos y archivos .bak de las rutas públicas; mover secretos a un gestor seguro. • Corregir permisos y configuración del servidor; revisar todo el árbol por exposiciones similares.
Recuperación	• Verificar que no queda información sensible accesible y monitorear nuevos accesos.
Evidencia	Logs de acceso, copia de los archivos expuestos (resguardo), hashes y línea de tiempo.
Criterio de cierre	Sin recursos sensibles accesibles, credenciales rotadas y causa de la exposición corregida y verificada.

PB-02	**Abuso de autorización y acceso a datos de la ciudadanía** Escenarios NOT-YOURS, SECOND-ACCOUNT, WRONG-ROLE (IDOR/BOLA y control de acceso roto).
Disparador	Patrón de acceso a expedientes de otros usuarios, cambios de rol no autorizados o creación de cuentas anómalas.
Responsables	Líder de incidente · SOC · Desarrollo/App · Jurídico.
Detección y análisis	• Correlacionar accesos por usuario y objeto para medir cuántos registros se consultaron. • Identificar cuentas y roles alterados o creados por el atacante.

Contención	• Deshabilitar las cuentas abusivas y revocar sesiones; **rotar credenciales** afectadas. • Bloquear el endpoint vulnerable o aplicar control de acceso temporal.
Erradicación / remediación	• Implementar **autorización por objeto** (verificar propiedad del recurso) en las APIs afectadas. • Revisar y corregir la asignación de roles y eliminar cuentas ilegítimas.
Recuperación	• Restablecer el servicio con el control corregido y vigilar accesos a datos.
Evidencia	Registros de acceso por objeto, inventario de cuentas/roles alterados, alcance de datos consultados.
Criterio de cierre	Control de acceso corregido y verificado, cuentas ilegítimas eliminadas y alcance de datos notificado a Jurídico/INAI si procede.

PB-03	**Inyección en aplicación web (SQLi / XSS almacenado)** Escenarios TOO-DEEP, SILENT-ANSWER, STORED-WORDS (inyección SQL —incluida ciega— y XSS almacenado).
Disparador	Firmas del WAF/IDS de inyección o XSS, errores de base de datos anómalos o contenido malicioso persistente en el portal.
Responsables	Líder de incidente · SOC · Desarrollo/App · DBA.
Detección y análisis	• Identificar el parámetro y endpoint vulnerable y si hubo exfiltración o alteración de datos. • Localizar el payload almacenado (XSS) y su alcance a usuarios.
Contención	• WAF en bloqueo para el vector; deshabilitar temporalmente la función afectada. • Depurar el contenido malicioso almacenado.
Erradicación / remediación	• **Consultas parametrizadas**/ORM y validación de entradas (SQLi); **codificación de salida** y política CSP (XSS). • Revisar la base de datos por manipulación y repararla desde respaldo confiable.
Recuperación	• Desplegar la corrección, re-probar el endpoint y restablecer la función con monitoreo reforzado.
Evidencia	Logs del WAF y de la aplicación, payloads, consultas afectadas y registros de base de datos.
Criterio de cierre	Vector cerrado y verificado por re-test, contenido malicioso eliminado e integridad de datos confirmada.

PB-04	**Fraude en pagos y compromiso de proveedor (cadena de suministro)** Escenarios PAYMENT-PATH, TRUSTED-SUPPLIER (manipulación de operaciones de pago y confianza en un proveedor).
Disparador	Inconsistencias en operaciones de pago, flujos manipulados o actividad anómala asociada a un proveedor de confianza.
Responsables	Líder de incidente · SOC · Finanzas · Administración/Compras · Jurídico.
Detección y análisis	• Reconstruir las transacciones afectadas y el punto de manipulación del flujo de pago. • Evaluar el acceso y la confianza otorgados al proveedor comprometido.
Contención	• Suspender el flujo o la integración de pago afectada y las credenciales del proveedor. • Congelar operaciones sospechosas y notificar a Finanzas.
Erradicación / remediación	• Corregir la lógica de autorización y validación del proceso de pago. • Revisar y **restringir los accesos de terceros** (mínimo privilegio) y revocar confianza indebida.
Recuperación	• Reactivar el proceso con controles reforzados, conciliación financiera y vigilancia.
Evidencia	Registros transaccionales, logs de integración del proveedor y conciliaciones.
Criterio de cierre	Flujo de pago corregido, accesos de terceros restringidos y verificados, e impacto financiero conciliado.

PB-05	**Suplantación y evasión de autenticación** Escenarios BEHIND-THE-DESK, WHO-ARE-YOU, BEYOND-THE-WEB (spoofing de cabeceras como `X-Forwarded-For`, evasión de identidad y enumeración de la red interna).
Disparador	Accesos que eluden controles de origen, cabeceras manipuladas o enumeración/escaneo de la red interna.

Responsables	Líder de incidente · SOC · Redes · TI.
Detección y análisis	• Identificar cómo se evadió el control (cabeceras de confianza, identidad suplantada). • Mapear qué segmentos internos fueron enumerados o alcanzados.
Contención	• Bloquear el acceso evasivo y las direcciones origen; reforzar reglas de red. • Aislar los segmentos expuestos a la enumeración.
Erradicación / remediación	• **No confiar en cabeceras** (`X-Forwarded-For`) para autenticar/autorizar; validar en el servidor. • Endurecer segmentación y reducir la superficie interna visible.
Recuperación	• Restablecer con los controles de identidad corregidos y monitoreo de la red interna.
Evidencia	Logs de proxy/servidor con cabeceras, registros de red y rastros de enumeración.
Criterio de cierre	Evasión cerrada y verificada, segmentación reforzada y sin enumeración activa.

PB-06	**Compromiso OT e integridad de firmware (control del proceso de agua)** Escenarios EYES-ON-THE-PLANT, TRUST-THE-PACKAGE, CHAIN-REACTION, NOW-YOU-CONTROL (acceso a OT, firmware no firmado, cascada y toma de control del proceso).
Disparador	Cambio de setpoint fuera de rango, firmware no firmado, pérdida de telemetría o avalancha de alarmas en el proceso de agua.
Responsables	Líder de incidente · Operaciones OT · SOC · Dirección General · Protección civil (si hay riesgo a la población).
Detección y análisis	• Confirmar con Operaciones el estado real del proceso y el parámetro alterado. • Determinar el origen del cruce IT→OT y si el firmware fue modificado.
Contención	• Llevar el proceso a **estado seguro** mediante procedimientos de Operaciones; **cerrar el cruce IT→OT**. • Aislar los equipos OT afectados preservando la seguridad física.
Erradicación / remediación	• Restaurar firmware **firmado y verificado** del fabricante y setpoints aprobados. • Corregir la segmentación y los accesos que permitieron el cruce.
Recuperación	• Reactivar OT **por fases**, con validación de telemetría, pruebas y monitoreo reforzado; rollback disponible.
Evidencia	Registros del historiador OT, versiones de firmware y hashes, bitácora de maniobras de Operaciones.
Criterio de cierre	Proceso estable y bajo control, firmware íntegro verificado, segmentación restablecida y autorización de Operaciones y Dirección.

10. Post-incidente y mejora

10.1 Cierre e informe final

- El **cierre formal** lo declara el líder de incidente (con el CISO en SEV-1/2) al cumplirse los criterios de cierre de cada playbook y verificarse la recuperación.
- Se elabora un **informe final** con: línea de tiempo, causa raíz, alcance e impacto, acciones tomadas, evidencia, notificaciones realizadas y costo estimado.

10.2 Lecciones aprendidas

Dentro de los **cinco días hábiles** posteriores al cierre se realiza una reunión de lecciones aprendidas con el ERI y las áreas involucradas: qué funcionó, qué falló (p. ej., los errores observados en INTERAFAS-LAB), tiempos, coordinación y decisiones.

10.3 Acciones correctivas y seguimiento

- Cada hallazgo se traduce en una **acción correctiva** con responsable y fecha, y se registra en un **tablero de seguimiento**.
- Las acciones alimentan el **SGSI** (ISO/IEC 27001, cláusula 10 — mejora continua): actualización de controles, políticas y capacitación.
- El incidente **no se considera resuelto** hasta que las acciones críticas estén implementadas o cuenten con un plan aprobado y verificado.

10.4 Métricas (KPI)

Indicador	Qué mide
MTTD — tiempo de detección	Tiempo entre el inicio del incidente y su detección.
MTTA — tiempo de reconocimiento	Tiempo entre la alerta y el inicio de la atención.
MTTR — tiempo de respuesta/recuperación	Tiempo hasta contener y hasta restablecer la operación segura.
Permanencia del atacante (dwell time)	Tiempo que el atacante estuvo presente sin ser detectado.
Cumplimiento de SLA	% de incidentes atendidos dentro del tiempo objetivo por severidad.
Acciones correctivas cerradas	% de acciones implementadas en plazo; reincidencia de incidentes similares.